DisputeDesk — Phase 2 Report

Secure multi-user foundation: sign-in, roles and per-account dispute access

Date **3 November 2026** Commit **aa15514** (not pushed) Branch **master**

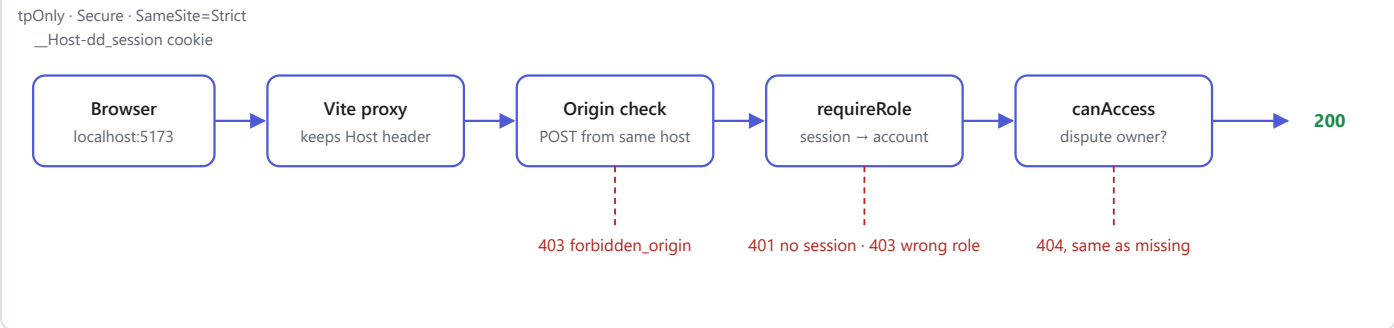
Summary. DisputeDesk now requires sign-in. Each account sees only its own disputes, admin is read-only, and the server decides the role and account on every request. All tests pass, the behaviour was checked in a real browser, and no live PayPal or Gemini calls were made.

104/104	50/50	0	0
Server tests (23 new)	Client tests (8 new)	Secrets in the commit	New dependencies

1. Results

Check	Result
Server tests	104 / 104 pass (81 existing, now signed in; 23 new)
Client tests	50 / 50 pass (42 existing; 8 new)
Type checks	Server and client pass
Production build	Passes; no demo records, hashes or passwords in the bundle
Original sandbox scripts	`draft-response.js` and `evidence-checklist.js` still run
Browser check	Passed on `localhost:5173` for every role
Live calls	None (AI off, sandbox never opened)

2. How a request is checked



3. What was built

- **Passwords.** scrypt from Node's built-in `node:crypto`, a random salt per account, constant-time comparison. An unknown email still runs a hash check, so response time does not reveal which emails exist.

- **Sessions.** Random token; the server stores only its hash. Ends after 30 minutes idle, 8 hours after sign-in, on sign-out, or on server restart. Every sign-in issues a new token.
- **Cookie.** `__Host-dd_session` with `HttpOnly; Secure; SameSite=Strict; Path=/`. Page scripts cannot read it.
- **Sign-in limit.** 10 failures per email or address, then a 15-minute lock (HTTP 429). The same error appears whether the email or the password was wrong.
- **Cross-site requests.** On top of `SameSite=Strict`, a POST that carries an `Origin` header must come from the page's own host.
- **Roles.** Every protected route checks the role on the server. A role or account ID sent by the browser is ignored; tests send forged ones to prove it.
- **Demo data.** Demo disputes are no longer bundled into the browser. They come only from the server, filtered to the signed-in account. `client/src/data.ts` was removed and Vite no longer serves the demo JSON files.

Who can reach what

Route	Admin	Merchant A	Merchant B	Buyers
Dispute list	all 3	DEMO-1001, 1002	DEMO-1003	403
Buyer dispute list	403	403	403	own only, reduced fields
Account list	yes, no hashes	403	403	403
PayPal sandbox	yes	yes	403	403
Analysis, validation example	yes	own only	own only	403
AI draft	403 (read-only)	own only	own only	403

Another account's dispute returns 404, exactly like a missing one, so dispute IDs cannot be probed.

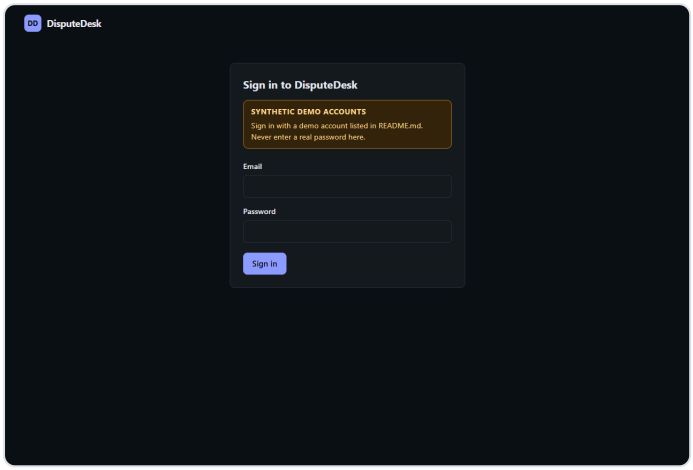
Demo accounts

Account	Role	Email	Can see
Demo Admin	admin	`admin@demo.disputedesk.test`	everything, read-only
Demo Merchant A	merchant	`merchant-a@demo.disputedesk.test`	DEMO-1001, DEMO-1002, PayPal sandbox
Demo Merchant B	merchant	`merchant-b@demo.disputedesk.test`	DEMO-1003
Demo Buyer A	buyer	`buyer-a@demo.disputedesk.test`	DEMO-1001
Demo Buyer B	buyer	`buyer-b@demo.disputedesk.test`	DEMO-1002, DEMO-1003

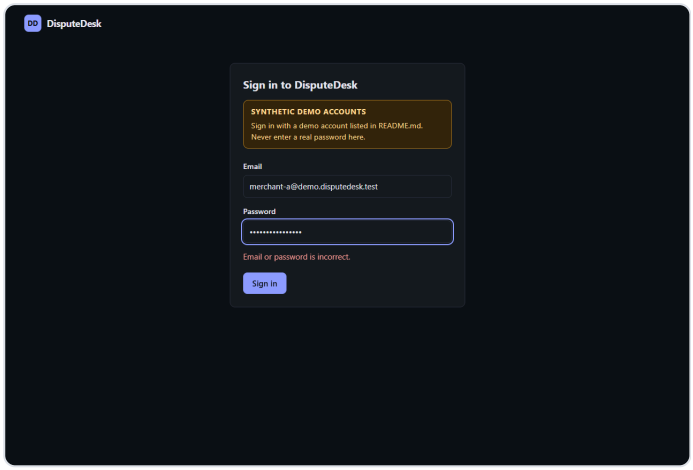
Synthetic accounts on the reserved `.test` domain. `demo-accounts.json` stores only scrypt hashes. Passwords are in README.md only and are deliberately left out of this report.

4. Browser walkthrough

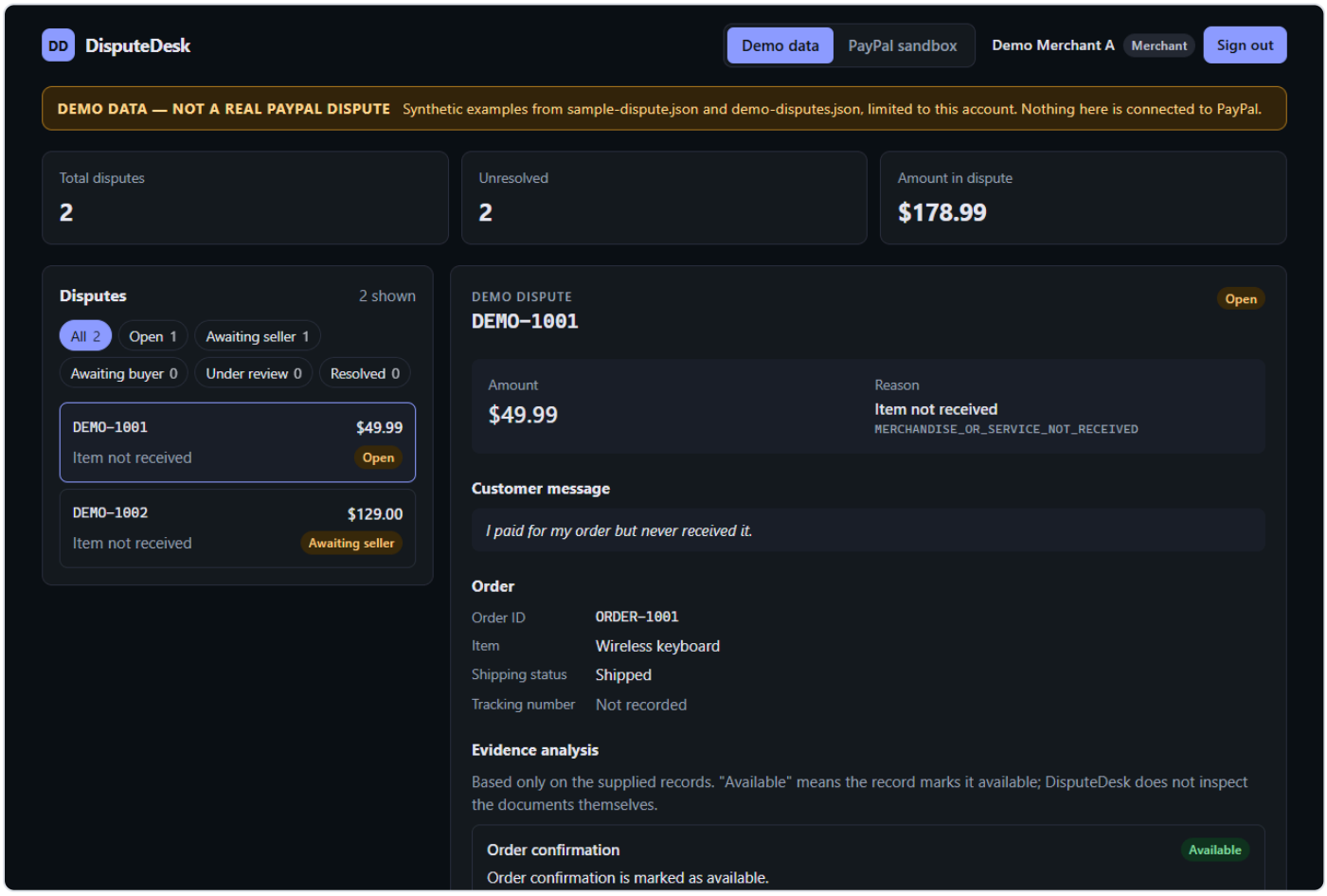
Captured from the running app at `http://localhost:5173` through the Vite proxy, with a fresh browser profile. Passwords appear only as masked dots.



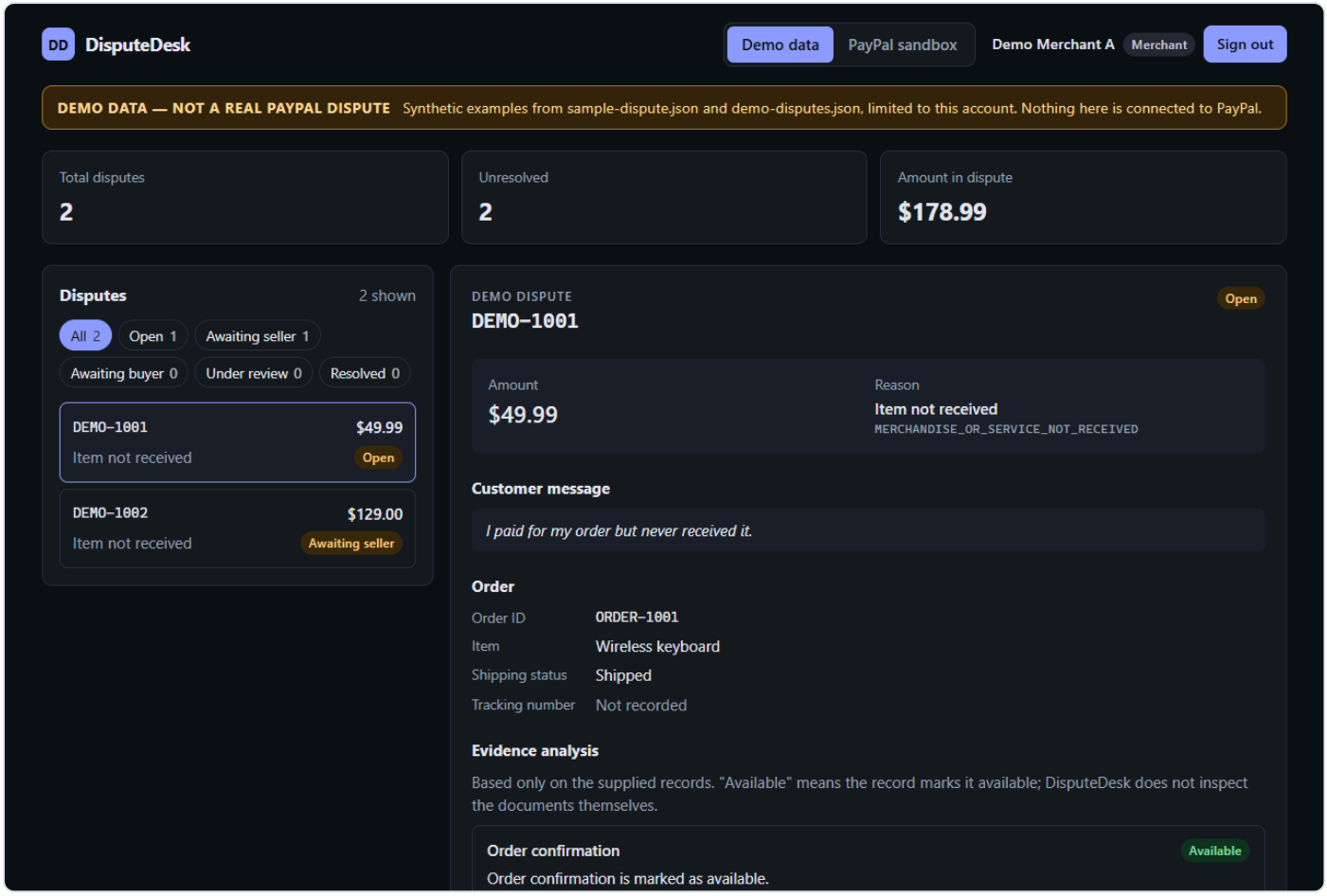
Signed out. Only the sign-in form, with the synthetic-account warning.



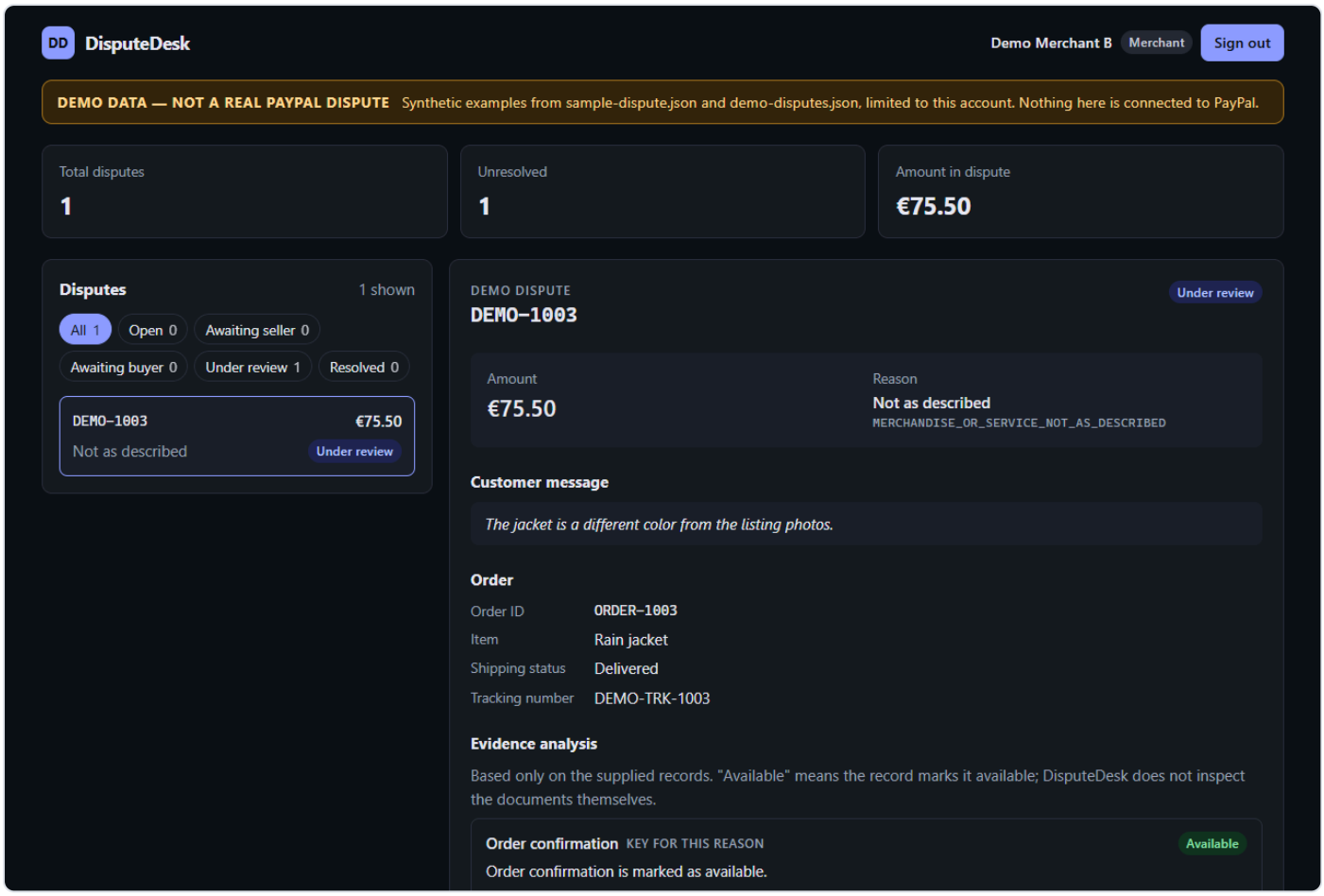
Wrong password. Generic message; it does not say which field was wrong.



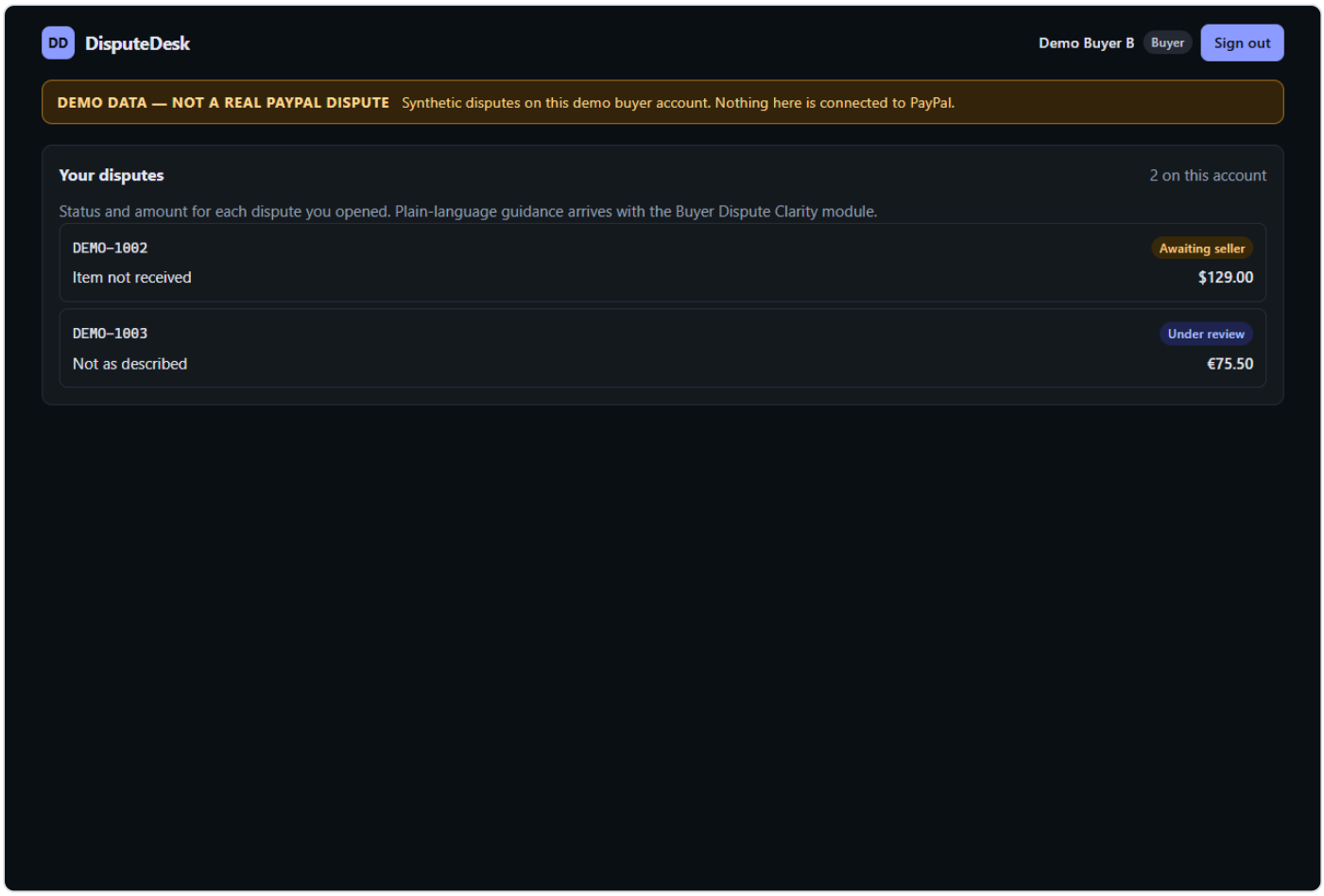
Merchant A. Sees only DEMO-1001 and DEMO-1002, and has the PayPal sandbox switch. Requesting DEMO-1003 returns 404.



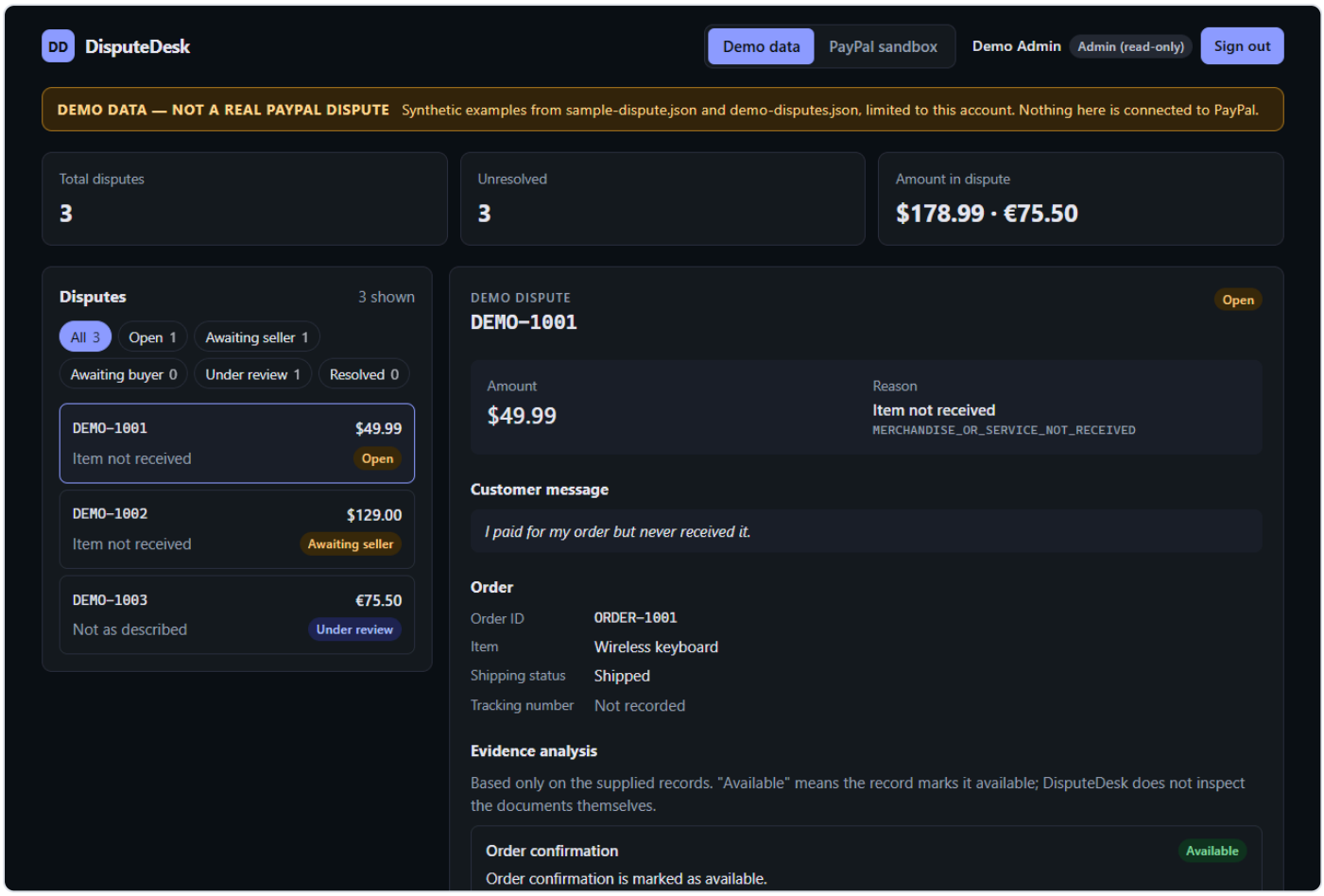
Merchant A, dispute detail. The evidence analysis is unchanged from Phase 1 and is still labelled as demo data.



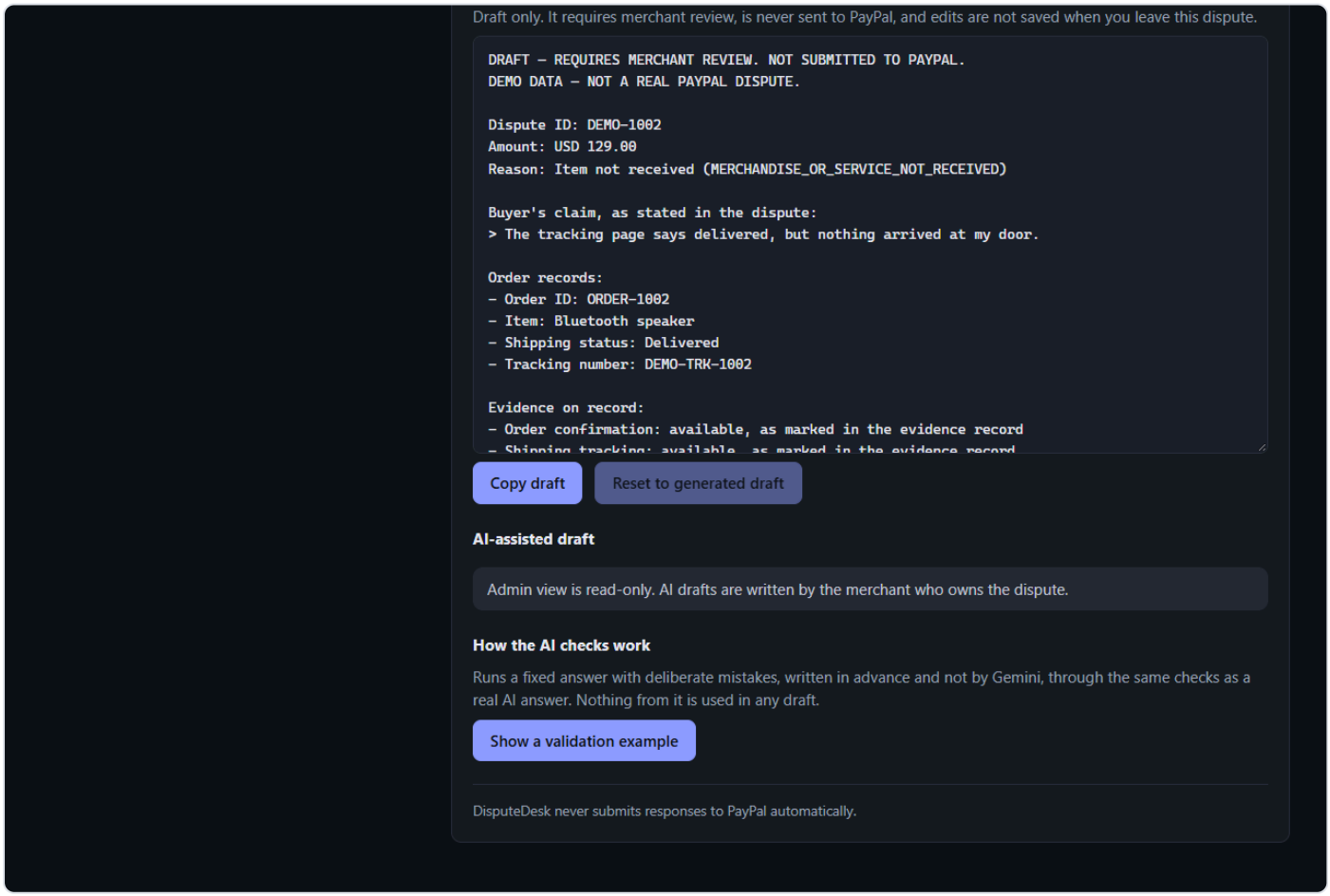
Merchant B. Only DEMO-1003. No sandbox switch, because this account has no sandbox access.



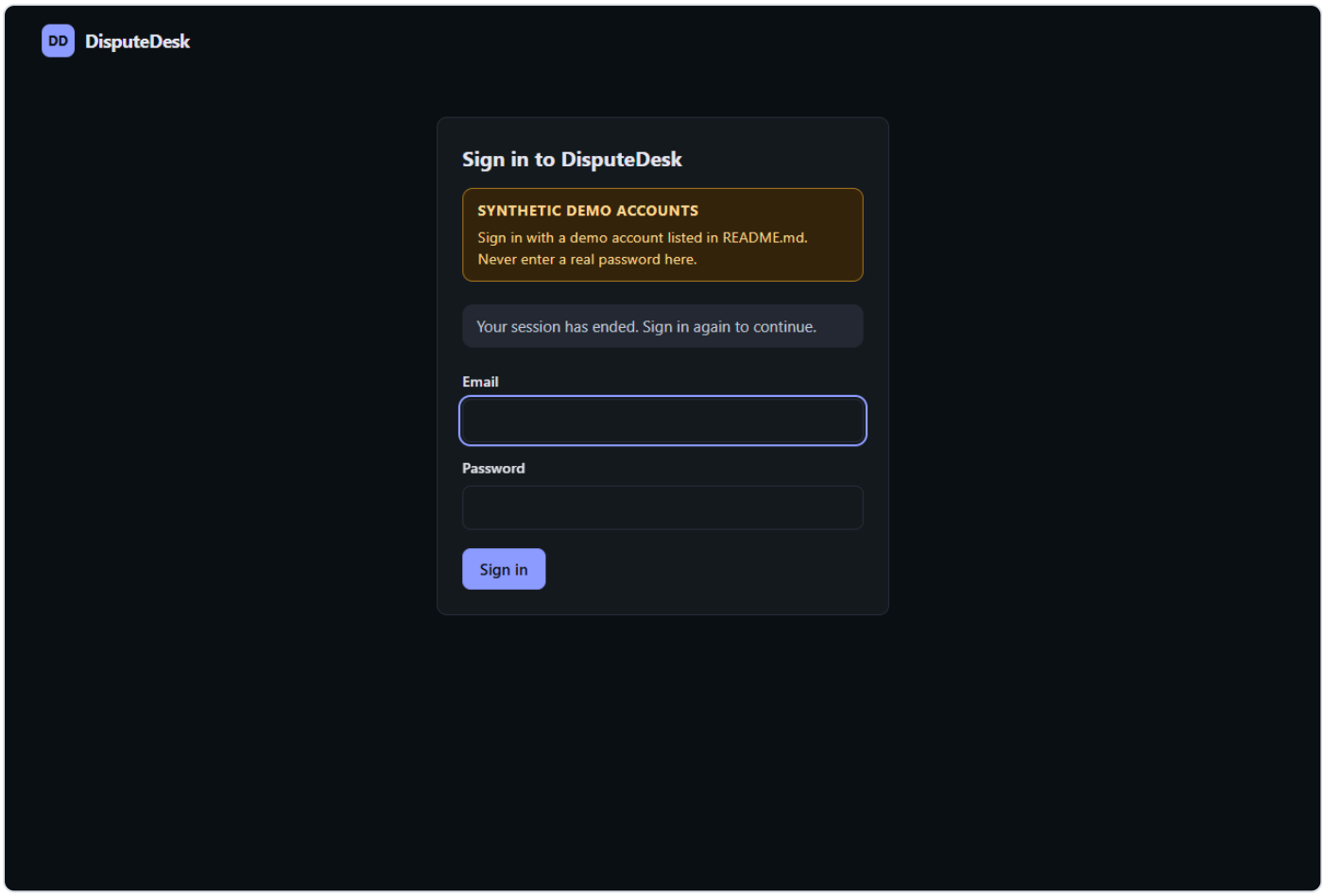
Buyer B. DEMO-1002 and DEMO-1003 with status and amount only. No merchant order or evidence records. Merchant routes return 403.



Admin. All three disputes and the "Admin (read-only)" badge.



Admin, read-only. No "Generate AI draft" button; the AI route itself returns 403. DELETE on the account list returns 404.



Session ended. When the server session ends, the next request returns 401 and the app returns to sign-in with a notice.

5. Bug found in the browser, and fixed

Symptom. The first browser sign-in failed with "Requests must come from the DisputeDesk page itself."

Cause. Vite's short proxy form (`"/api": "http://..."`) quietly turns on `changeOrigin` , which rewrites `Host` to `127.0.0.1:3001` . The server then saw two different hostnames.

Fix. `changeOrigin: false` in `client/vite.config.ts` , so the server sees the browser's `localhost:5173` . The security check itself was not loosened.

Why tests missed it. Unit tests don't pass through the Vite proxy, which is why the browser check mattered.

6. Security review

Check	Result
`.env` values or key-shaped strings in the commit	None
Passwords, tokens or emails written to logs	None
`innerHTML`, `localStorage`, `eval`	None used
Routes without a role check	Only sign-in, sign-out and health, as intended
Sign-in input	Type and length checked; 1 kB body limit
Unknown `/api` routes	JSON 404 instead of Express's HTML page
`npm audit`	Not run (calls the npm registry)

7. Changed files

Area	New	Changed	Removed
Server	`auth.ts`, `auth.test.ts`	`app.ts`, `app.test.ts`, `validate.ts`, `index.ts` (comment)	—
Shared and data	`demo-accounts.json`	`shared/types.ts`	—
Client	`auth.ts`, `auth.test.ts`, `Login.tsx`	`App.tsx`, `sandbox.ts`, `AnalysisPanel.tsx`, `DisputeDetail.tsx`, `styles.css`, `ui.test.ts`, `vite.config.ts`	`data.ts`
Docs	—	`README.md`, `CLAUDE.md`	—

8. Remaining risks

- **In-memory sessions and sign-in limit.** A restart signs everyone out, and only one server process is supported. A persistent store is planned.
- **Rate limit covers sign-in only.** Other routes have none; the AI route still allows one draft per dispute at a time.
- **Shared local address limit.** Through the proxy every request comes from `127.0.0.1`, so 10 failed sign-ins across all accounts lock sign-in for 15 minutes.
- **No security headers** (CSP, X-Frame-Options). Pages come from Vite's dev server; these are needed before any hosted version.
- **Demo passwords in the README.** Acceptable only because the accounts are synthetic and the server listens on this machine only.
- **Not tested:** Safari with `Secure` cookies on `http://localhost`, and the 127.0.0.1 vs localhost cookie split (Vite listens on localhost only).